

BUILD-API.md

17. Sécurité commune

Version : V1

Statut : Référentiel officiel de sécurité des API de Vitala

17.1 Objectif

Cette section définit les règles de sécurité communes applicables à l'ensemble des API de Vitala.

Elle garantit que toutes les interfaces exposées par la plateforme respectent un niveau homogène de protection, indépendamment du domaine métier concerné.

Les règles définies ici sont obligatoires pour toutes les API publiques, privées, internes et d'administration.

17.2 Principes fondamentaux

Les API de Vitala appliquent les principes suivants :

- Security by Design
- Deny by Default
- Least Privilege
- Zero Trust
- Defense in Depth
- Privacy by Design

La sécurité est intégrée dès la conception et ne doit jamais être ajoutée après le développement.

17.3 Chiffrement des communications

Toutes les communications doivent utiliser :

- HTTPS uniquement ;
- TLS dans sa version supportée la plus récente ;
- certificats valides.

Les connexions HTTP non sécurisées sont interdites.

17.4 Authentification

Toute API protégée exige une authentification valide.

Les mécanismes autorisés sont :

- JWT émis par le système d'authentification ;
- jetons de service pour les traitements internes ;
- authentification machine à machine lorsque nécessaire.

Les identifiants ne doivent jamais être transmis dans les paramètres d'URL.

17.5 Autorisation

L'authentification ne suffit pas à autoriser une opération.

Chaque requête doit vérifier :

- le rôle de l'utilisateur ;
- les permissions associées ;
- les politiques RLS ;
- les règles métier applicables.

Toute action non autorisée doit être refusée.

17.6 Validation des données

Toutes les entrées utilisateur doivent être validées.

Les validations portent notamment sur :

- le type ;
- le format ;
- la longueur ;
- les plages de valeurs ;
- les règles métier.

Aucune donnée non valide ne doit être traitée.

17.7 Protection contre les attaques

Les API doivent être protégées contre :

- injections SQL ;

- injections NoSQL ;
- Cross-Site Scripting (XSS) lorsque applicable ;
- attaques par force brute ;
- attaques par rejeu (Replay Attack) ;
- élévation de privilèges ;
- accès non autorisés.

Les bibliothèques et mécanismes de sécurité validés doivent être privilégiés.

17.8 Limitation du trafic (Rate Limiting)

Les API doivent mettre en œuvre des mécanismes de limitation afin de prévenir :

- les abus ;
- les attaques par déni de service ;
- les usages excessifs.

Les limites peuvent varier selon :

- le rôle ;
 - le type d'API ;
 - le client.
-

17.9 Journalisation

Les opérations sensibles doivent être journalisées.

Les journaux doivent inclure, lorsque cela est pertinent :

- identifiant de la requête ;
- utilisateur ;
- date et heure ;
- ressource concernée ;
- résultat de l'opération.

Les informations sensibles ne doivent jamais être enregistrées en clair.

17.10 Gestion des données sensibles

Les données sensibles doivent :

- être minimisées ;
- être protégées ;
- ne jamais être exposées inutilement ;
- être masquées lorsque nécessaire.

Les réponses API ne doivent retourner que les informations strictement nécessaires.

17.11 Gestion des secrets

Les secrets (clés API, jetons, mots de passe, certificats) doivent :

- être stockés dans un gestionnaire sécurisé ;
 - ne jamais être intégrés au code source ;
 - être renouvelés périodiquement ;
 - être accessibles uniquement aux services autorisés.
-

17.12 Audit de sécurité

Les API critiques doivent faire l'objet :

- d'audits réguliers ;
- de tests de sécurité ;
- de revues de code ;
- de contrôles de conformité.

Les vulnérabilités identifiées doivent être corrigées avant la mise en production.

17.13 Gestion des incidents

Toute tentative d'accès non autorisé ou comportement suspect doit pouvoir être :

- détecté ;
 - enregistré ;
 - signalé ;
 - traité selon les procédures de sécurité de Vitala.
-

17.14 Références croisées

Cette section est directement liée à :

- BUILD-SECURITY.md ;
- DATABASE-RLS-MATRIX.md ;
- DATABASE-DICTIONARY.md ;
- BUILD-SUPABASE.md ;
- BUILD-ARCHITECTURE.md.

Toutes les règles de sécurité doivent rester cohérentes entre ces documents.

17.15 Conclusion

La Sécurité commune constitue le cadre de référence pour toutes les API de Vitala.

Elle garantit une protection homogène des ressources, une application systématique des contrôles d'accès et une défense robuste contre les principales menaces, tout en assurant la confidentialité, l'intégrité et la disponibilité des données.